

Ecco il **piano operativo completo passo-passo** per strutturare il tuo progetto/portfolio, con la mappatura esatta degli strumenti gratuiti preinstallati dentro la VM di Trace Labs e la procedura di raccolta forense.

1. Architettura dell'Ambiente e OPSEC (Messa in Sicurezza)

Prima di iniziare qualsiasi ricerca, configuri il tuo punto di partenza:

1. **Host:** Il tuo PC principale (Windows/Mac) esegue la Macchina Virtuale.
2. **VM: Trace Labs OSINT VM** importata su VirtualBox o VMware.
3. **Instradamento / Rete:**
 - Imposta la scheda di rete della VM su **NAT**.
 - Attiva una VPN gratuita (es. ProtonVPN Free) o il browser con instradamento su rete **Tor** dentro la VM.
4. **Browser Operativo:** Apri Firefox/Brave all'interno della VM senza fare il login a NESSUN servizio personale o social network.

2. Il Flusso di Lavoro Passivo e gli Strumenti Nativi di Trace Labs

Per coprire "tutti i metodi passivi possibili", segui le **4 fasi di analisi**, usando **esclusivamente gli strumenti gratuiti già presenti nel menu di Trace Labs**:

Plaintext

[Fase 1: Mappatura Entità] → [Fase 2: Footprinting & Leaks] → [Fase 3: SOCMINT Passiva] → [Fase 4: GEOINT & Metadati]

FASE 1: Mappatura dell'Entità (Dominio, DNS e Infrastruttura)

Obiettivo: Scoprire sottodomini, server di posta e indirizzi IP senza scansionare direttamente la rete target.

- **crt.sh (Cert Transparency Logs):** Interroghi i certificati SSL pubblici per scoprire tutti i sottodomini (anche quelli nascosti o di test) creati dall'organizzazione target.
- **Amass / Sublist3r (Preinstallati - Terminale):**
Estraggono mappe di sottodomini aggregando registri pubblici e motori di ricerca.
- Bash

sublist3r -d target.com

-
-

- **WHOIS & SecurityTrails:** Per verificare storici dei proprietari di dominio e record DNS passivi.

FASE 2: Identità, Username e Data Leaks (Footprinting)

Obiettivo: Trovare e-mail, presenza su piattaforme terze e fughe di dati storiche.

- **Sherlock & Maigret (Preinstallati - Terminale):**

Inserisci lo username dell'entità o del soggetto (es. [marco_valli90](#)) per trovare su quali dei 500+ siti pubblici esiste quell'account.

- Bash

```
sherlock marco_valli90
```

```
maigret marco_valli90
```

-
-

- **Holehe (Preinstallato - Terminale):**

Inserisci l'indirizzo e-mail target. Il tool interroga i form di recupero password di decine di siti web (Deliveroo, Adobe, Dropbox, ecc.) per dirti dove quell'e-mail è registrata, **senza mai inviare mail o avvisi al target**.

- Bash

```
holehe target@email.com
```

-
-

- **HavelBeenPwned / DeHashed (Versione Web/API):** Per verificare se l'e-mail è comparsa in data breach storici pubblici.

FASE 3: SOCMINT Passiva & Motori di Cache (Zero Sockpuppet)

Obiettivo: Consultare contenuti social e impronta digitale usando solo intermediari.

- **Google & Yandex Dorking:**

Sfrutti sintassi avanzate per estrarre il testo già indicizzato dai motori:

- [site:\[linkedin.com/in/\]\(https://linkedin.com/in/\) "Nome Target"](#)
- ["Nome Target" filetype:pdf](#)
- [site:instagram.com "Nome Target"](#)

- **Alternative Frontends & Scraper:**

Invece di accedere alle piattaforme native, consulta i dati pubblici tramite gli specchi intermediari (es. **Picuki/Imginn** per Instagram, **Redlib** per Reddit, **Invidious** per YouTube).

- **Wayback Machine & Archive.today:**

Consulta le istantanee storiche delle pagine web e dei profili prima che venissero modificati o messi in modalità privata.

FASE 4: GEOINT & Estrattori di Metadati

Obiettivo: Estrarre coordinate e dettagli nascosti dai file e dalle immagini trovate online.

- **ExifTool (Preinstallato - Terminale):**

Se scarichi un documento PDF, una foto o un file dal sito target, lo analizzi con ExifTool per estrarre metadati (autore del file, versione software usata, data di creazione, coordinate GPS se presenti).

- Bash

```
exiftool immagine_target.jpg
```

-

-
- **Google Earth / PeakVisor / SunCalc:**
Per la geolocalizzazione passiva di foto pubbliche (analisi delle ombre, della vegetazione e del profilo delle montagne).

3. Procedura di Raccolta Forense e Catena di Custodia

Mentre esegui ciascuno di questi passaggi, applichi la procedura di conservazione delle prove dentro la VM:

1. **Cattura della Pagina:**
Apri la pagina web/risultato sul browser della VM e usa **SingleFile** o **GoFullPage** (estensioni preinstallate/disponibili) per salvare:
 - File **.png** (Cattura Visiva)
 - File **.html** (Codice DOM completo)
2. **Organizzazione Cartelle:**
Salvi i file nella struttura del progetto:
`~/Case_Files/Progetto_OSINT_Passivo/01_Evidenze_Grezze/`
3. **Generazione dell'Hash SHA-256 (Terminale Trace Labs):**
Appena terminata la sessione, apri il terminale nella cartella delle prove e generi l'impronta digitale cumulativa:
4. Bash

```
cd ~/Case_Files/Progetto_OSINT_Passivo/01_Evidenze_Grezze/
sha256sum * > registro_hash_evidenze.txt
```

- 5.
- 6.

4. Documentazione delle Note (CherryTree / Obsidian)

Nella VM di Trace Labs trovi già preinstallato **CherryTree** (o puoi usare **Obsidian**).

Mentre fai la ricerca, mantieni il tuo quaderno di campo digitale diviso in schede:

- **Node 1: Obiettivi & PIRs** (Cosa stiamo cercando).
- **Node 2: Mappa delle Relazioni** (Username \$ \rightarrow \$ Email \$ \rightarrow \$ Servizi trovati).
- **Node 3: Log delle Operazioni** (Data, ora UTC, comando o URL interrogato, esito).

5. La Struttura del Report da Presentare per il Portfolio

Quando hai concluso la ricerca passiva, redigi il tuo report (in formato Markdown da esportare poi in PDF) seguendo esattamente questa struttura formale:

1. **Intestazione & Metadati del Caso:** Titolo, data, analista, ambito applicativo.
2. **Ambiente Operativo & OPSEC:** Dichiaro l'uso della *Trace Labs OSINT VM*, della rete di anonimizzazione e l'assenza totale di interazione diretta.
3. **Metodologia (Non-Interactive Passive OSINT):** Spieghi perché non sono stati usati sockpuppet e come l'uso di intermediari (cache, dork, API) garantisce l'assenza di attribution risk.

4. **Matrice dei Risultati (Find):** Tabella con le informazioni scoperte (domini, e-mail, username, footprint, metadati estratti).
5. **Registro delle Evidenze (Catena di Custodia):** Tabella contenente Nome File, URL/Fonte, Timestamp e Hash SHA-256.
6. **Valutazione d'Intelligence (Admiralty System):** Valutazione della veridicità dei dati incrociati.
7. **Conclusioni & Raccomandazioni di Sicurezza.**

Perché questo progetto ha un valore altissimo per un Recruiter

Un progetto così strutturato risponde a tutti i requisiti di un'indagine aziendale o governativa reale: **è legale, rispetta la privacy e la compliance, ha costo zero, non crea incidenti di sicurezza e dimostra un controllo totale della catena di custodia e della strumentazione tecnica.**

PER RACCOLTA PROVE USARE L ESTENSIONE OSINT FORENSICS + CONFERMA HASH-256 DA TERMINALE BASH

[1. CATTURA]

Forensic OSINT salva il file e calcola subito l'Hash (H1) —> H1 va nel registro iniziale

[2. CONSERVAZIONE & ANALISI]

Il file rimane nella tua cartella delle prove durante la stesura del report

[3. VERIFICA FINALE]

Esegui `sha256sum` da terminale e calcoli l'Hash attuale (H2) —> Se H1 == H2 → Prova Inalterata

Perché questo passaggio "doppio" rafforza il tuo report:

1. **Dimostra la continuità temporale (Catena di Custodia):**
 - **L'Hash H1** (generato da Forensic OSINT) certifica lo stato del file al momento esatto dello scaricamento dal web (\$t_0\$).
 - **L'Hash H2** (generato da te da terminale prima di chiudere il caso, a \$t_1\$) certifica che durante tutta la fase di analisi, scrittura delle note e composizione del report, **il file sorgente non è mai stato aperto per errore con editor che ne hanno alterato i byte, non è stato corrotto e non è stato modificato.**
2. **Supera la dipendenza da un singolo strumento:**

Se un auditor o un recruiter dovesse chiederti: *"Come faccio a fidarmi dell'hash generato dall'estensione?"*, tu potrai mostrare che il dato è stato indipendente verificato tramite le utility native del sistema operativo Linux (**sha256sum**).

Come riportarlo nel tuo Report (Esempio Pratico)

Nella tabella della **Catena di Custodia** in fondo al tuo report, puoi inserire una nota metodologica molto elegante come questa:

ID Evidenza	File	Hash di Acquisizione (Forensic OSINT - UTC)	Hash di Verifica Finale (CLI Linux)	Stato Integrità
EVD-001	profilo.png	e3b0c44298fc1c14. ..	e3b0c44298fc1c14. ..	VALIDATO (Coincidente)

Nota di Tracciabilità: *L'hash di acquisizione è stato generato dall'estensione al momento del download. L'integrità del file è stata successivamente riconfermata tramite l'utility sha256sum da terminale prima del congelamento dell'archivio del caso.*